

web application as the registered user of the application.

Sometimes, attackers embed the malicious JavaScript code within hyperlinks. When the user clicks on the link, the script will automatically retrieve the user information, or even take over the user session, or start displaying strange advertisements to users.

Here's an example of the famous eCommerce website Lenskart, which turned out to be vulnerable to XSS (a few years ago as per the article available at <https://dgit.in/lenskartback>).



To avoid this attack on the web application, web developers should make sure the output based on the input parameters are properly encoded, both the input parameters and output value based on the inputs are filtered properly for special characters.

OWASP ZAP

The Open Web Application Security Project (OWASP) Zed Attack Proxy (ZAP) is the world's well-known security tool for developers to run penetration tests. Coming from the OWASP community, this is a completely free tool. The tool can help to find security vulnerabilities in web applications while developing and testing applications. The OWASP ZAP can be downloaded from GitHub and can be executed on operating systems that have Java installed.

OWASP ZAP helps website owners to detect the following threats –

- SQL Injection
- Cross-site Scripting
- Cross-site request forgery (CSRF)
- Broken access control
- Exposure of sensitive and critical information
- Under protected APIs, and more